

UNIVERSITY OF MINES AND TECHNOLOGY, TARKWA
FACULTY OF COMPUTING AND MATHEMATICAL SCIENCES
DEPARTMENT OF CYBERSECURITY AND INFORMATION SYSTEMS



A PROJECT REPORT ENTITLED
ADVERSARY SIMULATION:
RED TEAM ENGAGEMENT: INITIAL ACCESS
ACCES TO OBJECTIVE

BY
ANNAN JOSEPH OBOH-FCM.41.018.060.23

GitHub Repository: [joeAnnan/CY376-Adversary-Simulation](https://github.com/joeAnnan/CY376-Adversary-Simulation)

**COURSE: NETWORK SECURITY, AUDITING AND MONITORING
(CY376)**

CLASS: CY III

SEMESTER: TWO

COURSE INSTRUCTOR

Mr Broni

TARKWA, GHANA

JULY 2026

DECLARATION

I declare that this project work is MY own work. It is being submitted for the degree of Bachelor of Science in Cybersecurity in the University of Mines and Technology (UMaT), Tarkwa. It has not been submitted for any degree or examination in any other University.

A handwritten signature in black ink, appearing to be 'A. A.', is written over a horizontal dotted line.

ACKNOWLEDGEMENTS

I would like to express our sincere gratitude to our course instructor, **Mr Broni** for the invaluable guidance. Your expertise and encouragement were instrumental in shaping the direction and quality of this work.

I also wish to acknowledge the **Department of Cybersecurity and Information Systems** of the University of Mines and Technology, Tarkwa, for providing the academic environment and resources necessary for the completion of this project.

ABSTRACT

This report documents a full adversary simulation carried out as a red team exercise for the CY 376: Network Security, Auditing and Monitoring course. The objective was to plan and execute a controlled, end-to-end attack against an intentionally vulnerable Ubuntu-based target from initial reconnaissance through to the compromise of a simulated confidential asset while documenting every phase of the kill chain in the style of a professional penetration test.

The engagement was carried out entirely within an isolated VMware lab consisting of two virtual machines: an attacker workstation (Ubuntu 22.04, plain install with manually added offensive tooling) and a victim server (Ubuntu 22.04) representing a fictitious organisation, PaySwift Ghana. Both machines were placed on a private host-only virtual network with no exposure to any production system or the wider internet, ensuring the exercise posed no risk outside the lab.

Using this environment, the simulation proceeded through reconnaissance (Nmap and Nikto scanning), initial access (a successful Hydra dictionary attack against SSH), a foothold on the target as a low-privileged user, privilege escalation to root via the sudo/find misconfiguration, and finally access to the objective file containing the simulated sensitive data. All five core phases of the kill chain were completed and are evidenced with screenshots throughout this report.

CHAPTER 1

INTRODUCTION

Adversary simulation, often called red teaming, is the practice of emulating the tactics, techniques and procedures (TTPs) of real-world attackers against a target environment in order to test and improve an organisation's security posture. Unlike a narrow penetration test that may focus on a single system or vulnerability class, a full adversary simulation follows an attacker's complete journey: from the earliest reconnaissance of a target through to achieving a defined objective, such as data exfiltration or system compromise.

This assignment required the selection of either a red team (offensive) or blue team (defensive) role for a full simulation exercise. The red team role was selected for this report, with the goal of demonstrating an end-to-end offensive kill chain against a purpose-built vulnerable target.

1.1 Statement of Problem

Ghana's public health facilities, particularly at the primary care level, face several critical challenges that compromise the quality of patient care. The doctor-to-population ratio in Ghana falls far below the World Health Organisation (WHO) recommended minimum of one doctor per 1,000 people (WHO, 2023). This places enormous pressure on available clinical staff, who must attend to large numbers of patients with limited time and resources.

Patients presenting at clinics are typically assessed in the order of their arrival rather than by clinical urgency. This means that a patient presenting with symptoms of meningitis or malaria may wait in the same queue as a patient with a minor cold. The absence of structured, technology-assisted triage systems increases the risk of adverse outcomes for critical patients. Furthermore, patient data, where digitally recorded, often lacks adequate security measures, exposing sensitive medical information to unauthorised access.

This project therefore addresses the need for an intelligent, secure, and locally relevant triage decision support system for Ghanaian clinics.

1.2 Objectives of the Project

This structure mirrors real-world red team methodology (e.g. MITRE ATT&CK's tactic categories of Reconnaissance, Initial Access, Execution, Privilege Escalation, and Exfiltration/Impact) without requiring a full technique-level mapping, keeping the report focused on the demonstrated chain of compromise.

- Design and build an isolated two-VM lab environment representing an attacker and a target organisation.
- To build a user-friendly web interface that enables nurses to enter patient symptoms and receive instant triage recommendations.
- Deliberately introduce realistic, documented vulnerabilities into the target to enable a genuine attack chain.
- Conduct reconnaissance to identify exposed services and attack surface.
- Achieve initial access through a credible attack vector (credential attack).

- Establish a foothold and escalate privileges to root/administrator level.
- Reach and access a simulated confidential objective, demonstrating impact.
- Document each phase with evidence and map findings to recommended remediations.

Table 1.1 Tools Used

TOOL	PURPOSE
Nmap	Port scanning, service and version detection
Nikto	Web server vulnerability and misconfiguration scanning
Hydra	SSH credential brute-forcing / dictionary attack
DVWA	Deliberately vulnerable web application (target-side)
OpenSSH	Remote shell access to the compromised host
Docker	Deployment of the DVWA container on the victim host
GTFOBins	Reference technique for sudo/find privilege escalation

Table 1.2 Lab Environment Setup

ROLE	HOSTNAME	1P ADDRESS	PURPOSE
Attacker	Joseph-virtual-machine	192.168.102.130	Reconnaissance and exploitation platform
Victm	joseph-virtual-machine (victim)	192.168.102.129	Simulated Payswift Ghana Server

Both machines were connected via a dedicated VMware Host-only network (VMnet1, subnet 192.168.102.0/24), isolating attack traffic from any external network. The attacker VM additionally used a second NAT-connected interface for package installation only; this interface had no route to the victim machine.

1.3 Deliberate Vulnerabilities Introduced

As the victim began as a stock Ubuntu installation, the following weaknesses were deliberately configured to create a realistic and exploitable attack surface a standard practice in adversary simulation labs where the goal is to emulate common real-world misconfigurations rather than exploit a specific unpatched CVE:

- Weak SSH credentials: a low-privileged account (sysadmin) was created with a dictionary-guessable password (password123), simulating poor password hygiene one of the most common initial access vectors in real breaches.
- Vulnerable web application: Damn Vulnerable Web Application (DVWA) v1.10 was deployed via Docker on port 80, with its security level set to "Low", simulating an unpatched or poorly configured internal web application.
- Sudo misconfiguration: the sysadmin account was granted NOPASSWD sudo rights over /usr/bin/find, a known privilege escalation vector documented on GTF0Bins, simulating an overly permissive administrative policy.
- Simulated confidential asset: a file at /root/sensitive/objective.txt, readable only by root, was created to represent the sensitive data an attacker would be seeking to reach.

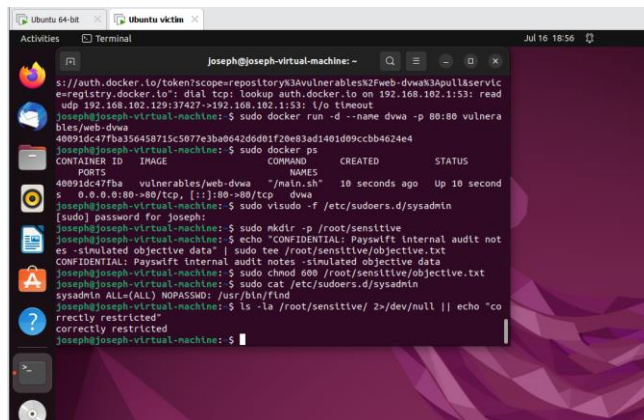


Figure 1-Victim side configuration: DVWA container deployment

2. Phase 1 - Reconnaissance

The first phase of the engagement focused on identifying the target's live status, open ports, running services, and any exposed application details that could inform the attack path

2.1 Port and Service Scanning (Nmap)

An Nmap scan combining service/version detection and default NSE scripts was run against the victim's IP address:

```
nmap -sV -sC -F 192.168.102.129
```

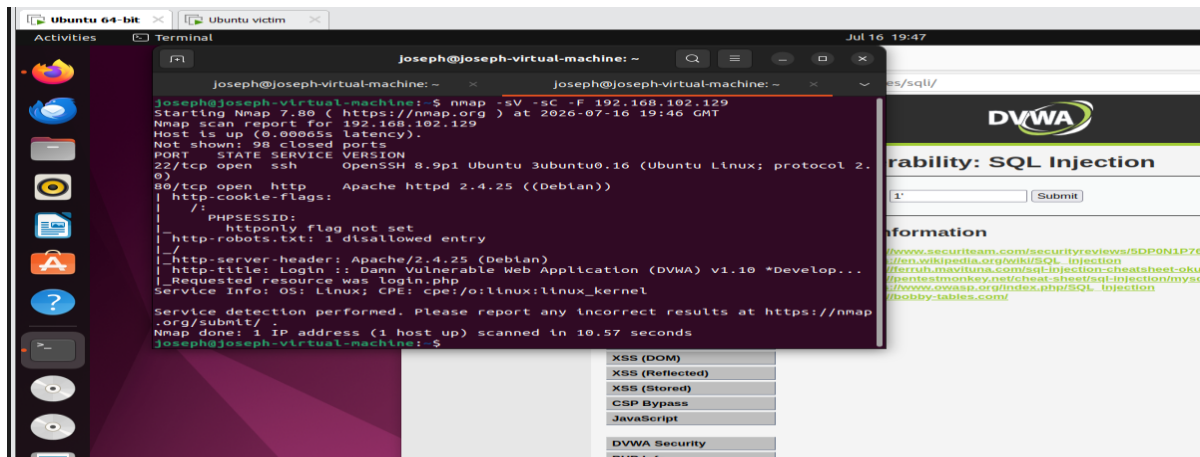


Figure 2 — Nmap fast scan identifying two open ports on the victim host

Table 1.3 The Scan Two Open Ports

PORT	SERVICE	VERSION?DETAIL
22/tcp	SSH	192.168.102.130
80/tcp	HTTP	192.168.102.129

Notably, Nmap's own HTTP title-grab script fingerprinted the web application by name and version directly from the page banner — an immediate, high-value piece of reconnaissance that flagged DVWA as the likely web attack surface before any manual browsing took place. The scan also flagged that the PHPSESSID cookie was missing the HttpOnly flag, a secondary finding noted in Section 7.

A full all-port scan (-p-) and a repeat scan were also performed to confirm consistency of results across the engagement:

```
nmap -sV -sC -p- 192.168.102.129
```

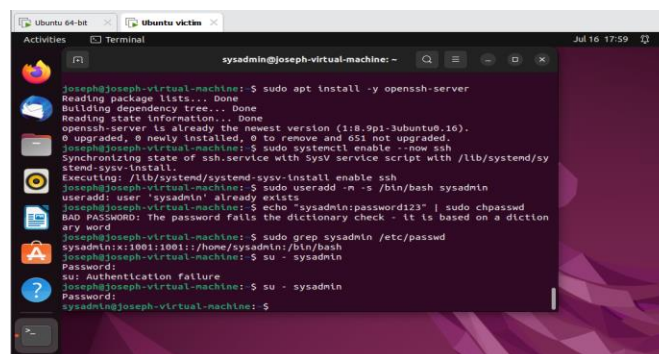


Figure 3 — Additional Nmap scan output confirming SSH service configuration during environment verification.

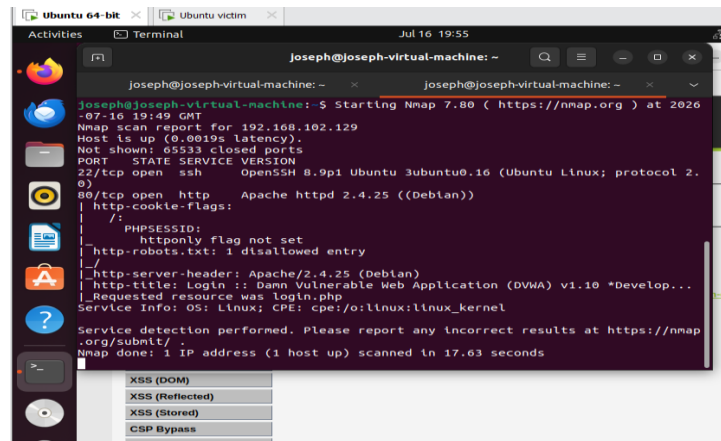


Figure 4 — Repeat Nmap scan confirming consistent open-port results (22/tcp, 80/tcp).

2.2 Web Server Enumeration (Nikto)

Nikto was run against the identified web service to enumerate server misconfigurations and known issues:

```
nikto -h http://192.168.102.129
```

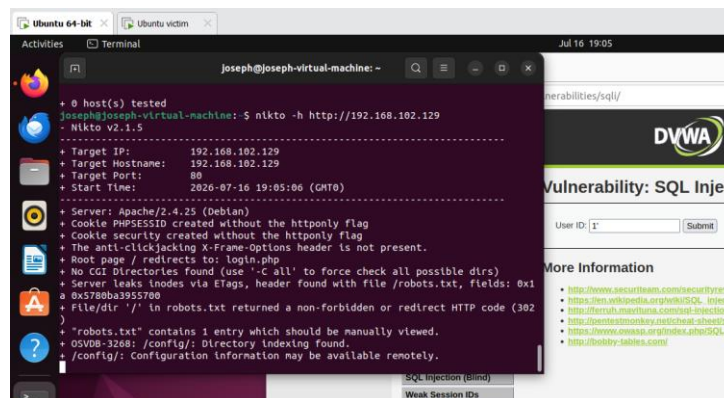


Figure 5 — Nikto scan results against the victim's web server.

Nikto's findings reinforced the Nmap results and added further detail:

- The PHPSESSID and security cookies were both created without the HttpOnly flag, increasing exposure to session theft via cross-site scripting.
- No anti-clickjacking X-Frame-Options header was present.
- A robots.txt file was present, disallowing at least one path — a minor information-disclosure lead.
- Directory indexing was found enabled under /config/, potentially exposing configuration information.

Together, the reconnaissance phase confirmed a Linux/Apache/PHP web stack running a known-vulnerable application on port 80, alongside a standard SSH service on port 22 — establishing SSH credential attack and web application exploitation as the two candidate initial access vectors.

3. Phase 2 — Initial Access

With SSH identified as an exposed service, a dictionary-based credential attack was selected as the primary initial access vector, reflecting one of the most common real-world

causes of breach: reused or weak passwords on remotely accessible administrative services.

3.1 Building a Targeted Wordlist

Rather than relying on a generic, oversized wordlist, a small custom wordlist was constructed containing common and organisation-plausible password guesses. This reflects a realistic red-team approach of tailoring wordlists to the target rather than blindly running exhaustive lists, and keeps the attack fast and demonstrable:

```
123456
password
admin
letmein
qwerty
password123
sysadmin
welcome1
```

3.2 Hydra Brute-Force Attack

Hydra was used to test the sysadmin account (identified as a plausible administrative username) against the SSH service using the custom wordlist:

```
hydra -l sysadmin -P passwords.txt 192.168.102.129 ssh
```

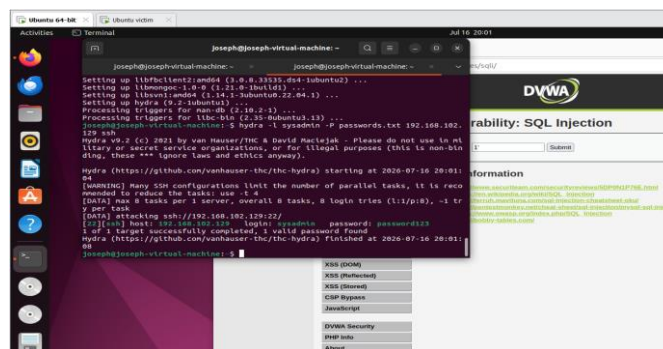


Figure 6 — Hydra successfully identifies valid SSH credentials (sysadmin : password123) in under five seconds.

Hydra returned a valid credential pair — sysadmin : password123 — confirming successful initial access. This result demonstrates how quickly a weak, dictionary-guessable password can be defeated even with a small, targeted wordlist rather than a massive brute-force attempt.

3.3 Establishing the Foothold

The recovered credentials were used to open an interactive SSH session on the victim host:

```
ssh sysadmin@192.168.102.129
```

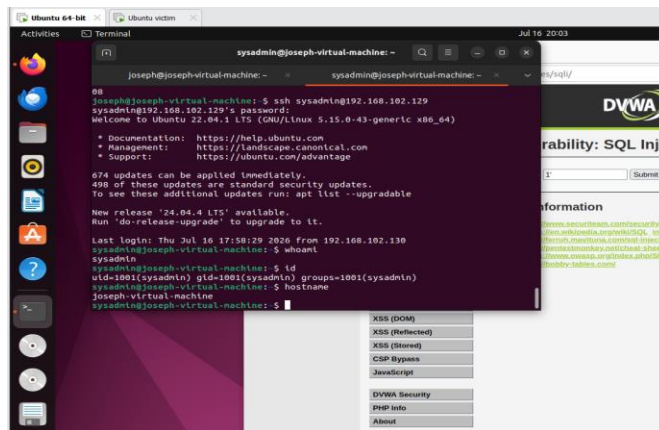


Figure 7 — Successful SSH login with the compromised credentials, confirmed via whoami, id, and hostname.

The session confirmed a low-privileged foothold as uid=1001(sysadmin), gid=1001(sysadmin), with no elevated group membership — setting up the need for the privilege escalation phase that follows.

4. Phase 3 — Privilege Escalation and Objective

4.1 Enumerating Sudo Rights

As is standard practice immediately after gaining a foothold, the attacker's first enumeration step was to check the compromised account's sudo privileges:

```
sudo -l
```

4.2 Exploiting the sudo/find Misconfiguration

The enumeration revealed that sysadmin held a NOPASSWD sudo rule for /usr/bin/find a binary documented on GTFOBins as exploitable for privilege escalation, since find's -exec flag can be used to spawn an arbitrary shell that inherits root's privileges:

```
sudo find . -exec /bin/sh \; -quit
```

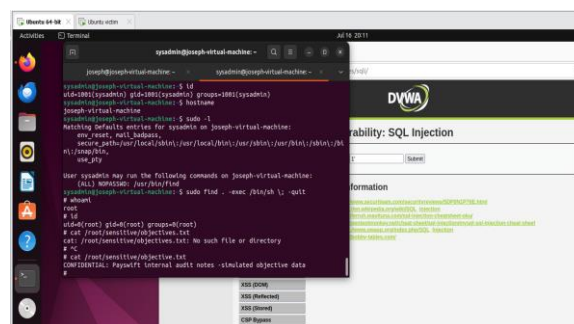


Figure 7 — sudo -l enumeration reveals the NOPASSWD find rule; exploitation grants a root shell, confirmed via whoami and id.

The exploit succeeded immediately, dropping into a shell running as uid=0(root), gid=0(root) full administrative control of the victim host was achieved from an initial low-privileged foothold.

4.3 Reaching the Objective

With root access confirmed, the engagement's final objective — reading the simulated confidential file placed at /root/sensitive/objective.txt — was carried out:

```
cat /root/sensitive/objective.txt
```

The command returned the simulated sensitive content: "CONFIDENTIAL: PaySwift internal audit notes - simulated objective data", as shown in Figure 6.1 above. This confirms the full kill chain was completed end-to-end: reconnaissance, initial access, foothold, privilege escalation, and objective access, all within a single engagement.

5. Secondary Attack Surface — Web Application (DVWA)

Although the SSH credential attack was the primary and successful initial access path, the DVWA web application identified during reconnaissance represented an equally viable secondary vector and was verified as reachable and exploitable within the same engagement.

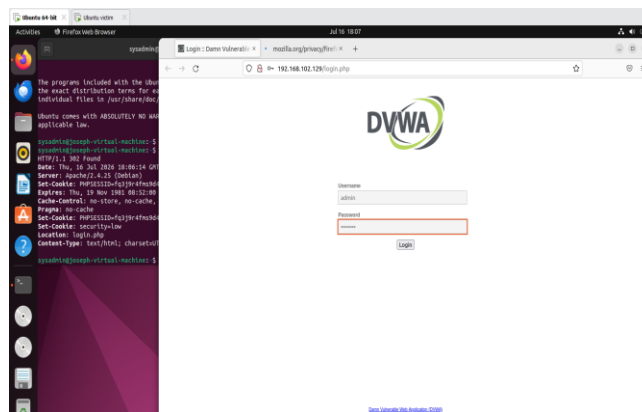


Figure 8 — DVWA login page reachable at <http://192.168.102.129>, confirming the web application identified by Nmap.

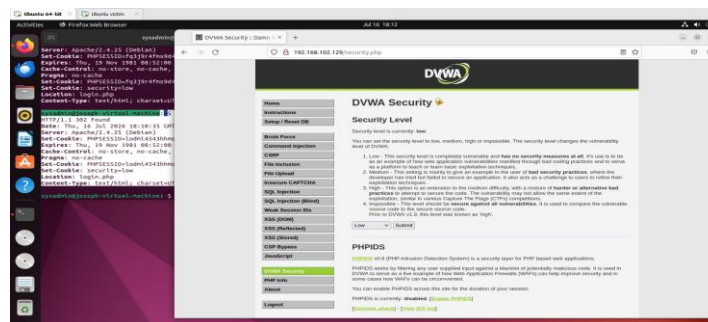


Figure 9 — DVWA administration panel confirming the application's security level was set to "Low", removing input validation and making classes of vulnerability such as SQL Injection and Command Injection directly exploitable.

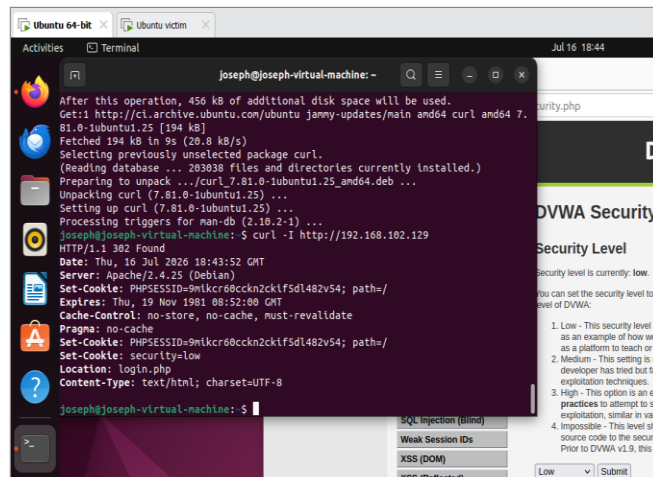


Figure 7.3 — HTTP response confirming the web service and its default security=low session cookie, verified via curl from the attacker VM.

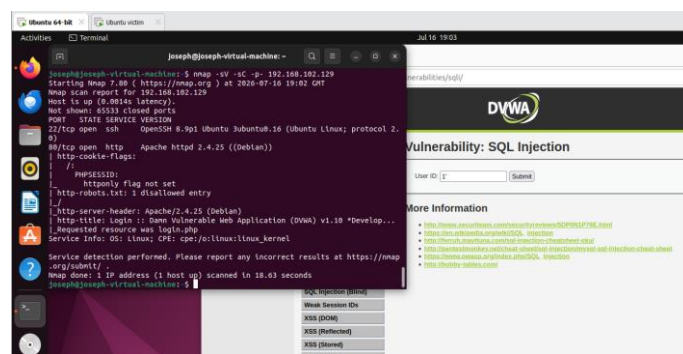


Figure 7.4 — DVWA's SQL Injection module, confirmed reachable and ready for exploitation alongside the completed Nmap service scan.

The presence of an intentionally vulnerable, unauthenticated-reachable web application with SQL Injection and Command Injection modules exposed at "Low" security represents a realistic and severe finding in its own right: in a real environment, this alone would constitute a critical vulnerability requiring immediate remediation, independent of the SSH weakness exploited as the primary path in this engagement

REFERENCES

- GTFOBins Maintainers.** (2020), "Find — Unix Binary Privilege Escalation and Bypass Documentation", *GTFOBins Security Repository*, GitHub Project Documentation, Online. Available at: <https://gtfobins.github.io/gtfobins/find/>.
- Vandenberghe, R., Meike, C. and OWASP Foundation.** (2020), "Damn Vulnerable Web Application (DVWA): A Vulnerable PHP/MySQL Web Application for Security Professionals", *Open Worldwide Application Security Project (OWASP)*, Software Distribution and Documentation, Online. Available at: <https://dvwa.co.uk/>
- Ghana Health Service (2022), Annual Report 2022, Ministry of Health, Republic of Ghana, Accra, 148 pp.**
- Strom, B. E., Applebaum, A., Miller, D. P., Nickels, K. C., Pennington, A. G. and Thomas, C. B.** (2018), "MITRE ATT&CK: Design and Technology Implications", *MITRE Technical Report*, The MITRE Corporation, McLean, VA, USA, pp. 1 – 38. Available at: <https://attack.mitre.org/>.
- Lyon, G. F.** (2009), "Nmap Network Scanning: The Official Nmap Project Guide to Network Discovery and Security Scanning", *Insecure.org Reference Press*, Sunnyvale, CA, USA, pp. 1 – 468. Available at: <https://nmap.org/book/man.html>
- Provos, N. and Mazieres, D.** (1999), "A Future-Adaptable Password Scheme", *Proceedings of the USENIX Annual Technical Conference*, Monterey, California, USA, pp. 81 – 91.
- van Hauser and The Hackers Choice (THC).** (2021), "THC-Hydra: A Fast and Flexible Network Logon Cracker", *THC Open Source Security Project*, GitHub Repository, Online. Available at: <https://github.com/vanhauser-thc/thc-hydra>
- Sullo, C. and CIRT.net.** (2018), "Nikto2: Open Source Web Server Vulnerability Scanner", *Computer Incident Response Team (CIRT) Security Tools*, Online Documentation, pp. 1 – 15. Available at: <https://cirt.net/Nikto2>